DOCUMENTAÇÃO TÉCNICA · POR SLIDE

Astro

Banco digital que resolve o split de IBS/CBS no ato do pagamento

Equipe CYMAG · SENAI São Caetano do Sul · Protótipo acadêmico — não é instituição financeira

O que é, em uma frase

Quando um cliente paga uma **cobrança com nota fiscal** a uma empresa, o banco **separa o imposto destacado na nota na hora** (CBS + IBS) e a empresa recebe **já líquido** — sem guia para pagar depois. Atende pessoa física (PF) e, no diferencial tributário, pessoa jurídica (PJ).

Pronto x feito do zero (resumo honesto)

Bibliotecas prontas (não reinventamos): FastAPI, SQLAlchemy/Alembic, PyJWT, passlib/bcrypt, cryptography (Fernet), **DeepFace** (modelos Facenet + anti-spoofing MiniFASNet, pré-treinados), React/TanStack Router, Capacitor, Next.js e a consulta pública da Receita (BrasilAPI).

Lógica que escrevemos do zero: o motor de split + o cronograma de transição; o modelo pessoa↔empresa↔vínculo e as contas de sistema; a dupla aprovação (maker-checker); os limites (noturno, carência, aparelho novo) mapeados às normas do BCB; a **prova de vida decidida no servidor** (desafio + geometria do giro + orquestração do anti-spoofing + cifra do embedding); o bloqueio cautelar + MED; a idempotência por carteira; Pix Automático/lote/webhooks; e toda a camada de API e as telas.

ARQUITETURA

Visão geral do sistema

Monorepo com três frentes independentes e um build que gera o .apk Android. A apresentação destaca o app, mas por trás existe uma **API completa** com as mesmas regras de negócio.

Módulo	Tecnologia	Papel
app/	Vite + TanStack Router (React, TypeScript) + Capacitor	O aplicativo (web e .apk). Foco da apresentação. TypeScript estrito.
site/	Next.js 15 + React 19	Vitrine institucional com o simulador de split.
backend/	FastAPI (Python), SQLAlchemy + Alembic, SQLite/PostgreSQL	API: pessoas, empresas, vínculos, split por NF-e, limites, cobrança, segurança. Suíte de testes (pytest).

Dois modos do app: **demonstração** (dados fictícios locais, sem servidor, para a banca interagir) e **conectado** ao backend via HTTP, quando `VITE_API_URL` aponta para a API.

Modelo de dados e identidade

- **Pessoa** (CPF, e-mail, biometria cifrada), **Empresa** (CNPJ, porte, regime de apuração) e **Vínculo** pessoa↔empresa (papel + alçada em R$). Uma pessoa opera várias empresas.
- **Carteiras** e **contas de sistema** separadas: `CAIXA`, `TRIBUTOS` (transitória do imposto retido) e `FISCO`.
- Além disso: transações, cobranças, limites, desafios de biometria, operações pendentes, contestações, autorizações de Pix Automático e logs de auditoria.

Autenticação e sessão

- Login **sempre da pessoa** (e-mail/CPF + senha; senha em hash bcrypt). Gera **JWT HS256**: access de **15 min** + refresh de **7 dias**.
- **Rotação de refresh** com **detecção de reuso**: se um refresh antigo é reusado, todas as sessões são revogadas. No banco guarda-se só o **hash SHA-256** do refresh — se o banco vazar, os tokens não servem.
- Para operar uma empresa, o app envia o número da conta no header `X-Conta`; o header `X-Dispositivo-Id` identifica o aparelho.

APRESENTAÇÃO

Roteiro por slide — o que mostrar e a lógica por trás

A apresentação tem 13 slides. Abaixo, para cada um: o que aparece na tela e **a lógica do backend que sustenta aquilo**. O slide da jornada (“Da boas-vindas ao comprovante”) é o do app embutido.

SLIDE 1

Capa — “O banco onde o imposto se resolve na hora da venda.”

> **Na tela**
> Logo Astro e a promessa central: o imposto deixa de ser uma apuração mensal e passa a ser resolvido no recebimento.

A lógica por trás (backend)

Enquadramento: hoje a empresa vende, recebe o bruto e só depois apura/paga IBS/CBS. O Astro antecipa isso para o momento do pagamento da cobrança com nota.

SLIDE 2

“O imposto sai da apuração e entra na venda.”

> **Na tela**
> Comparação do fluxo antigo (apurar depois) com o fluxo Astro (reter no ato).

A lógica por trás (backend)

No pagamento de uma cobrança vinculada à NF-e, o serviço `split_da_nota` retém **exatamente** a CBS e o IBS destacados na nota e credita o líquido ao recebedor. O retido vai para a conta de sistema `TRIBUTOS` na mesma transação.

Importante: o banco **não recalcula** o imposto — quem calcula item a item é a nota (classificação tributária de cada produto/serviço). Transferência comum nunca passa por aqui.

SLIDE 3

“2026 → 2033: o imposto cresce aos poucos.”

> **Na tela**
> Linha do tempo da transição da Reforma (EC 132/2023 e LC 214/2025), com as alíquotas subindo por ano.

A lógica por trás (backend)

O cronograma é uma tabela no código (`split_service.CRONOGRAMA`). Referências estimadas do regime pleno: CBS **8,8%** + IBS **17,7%** ≈ os **26,5%** do material oficial (serão fixadas por Senado e Comitê Gestor).

Ano	CBS	IBS	O que caracteriza
2026	0,9%	0,1%	Ano-teste; compensável com PIS/Cofins.
2027–2028	8,8%	0,1%	PIS/Cofins extintos, CBS cheia; IBS ainda simbólico.
2029–2032	8,8%	1,77% → 7,08%	IBS sobe 10/20/30/40% da referência; ICMS/ISS caem.
2033	8,8%	17,7%	IBS pleno; ICMS e ISS extintos.

SLIDE 4

“Você recebe já líquido, conciliado com a nota.”

> **Na tela**
> Tela de recebimento da empresa: bruto, CBS, IBS e líquido, com os selos ‘Regime padrão’, ‘Apuração quase pronta’, ‘Créditos acompanhados’ e ‘Governança’.

A lógica por trás (backend)

Modo de split **“inteligente” (offline)**: retém o bruto destacado, sem abater crédito em tempo real (o abatimento ‘superinteligente’ depende da plataforma pública da Receita/CGIBS, ainda sem padrão técnico).

O imposto fica na conta `TRIBUTOS` e um job (`/admin/tributos/repassar`) leva ao `FISCO` tudo o que foi retido antes do dia corrente — repasse **D+1**. Créditos são **informação** (fonte e data); a “restituição prevista” é só min(crédito informado, imposto retido). Quem restitui é o fisco, na apuração.

SLIDE 5

“Pessoas e empresas, cada uma com o que precisa.”

> **Na tela**
> Dois cards: Pessoa física (benefícios) e Pessoa jurídica (split e gestão).

A lógica por trás (backend)

PF: Pix/transferências **sem retenção** (não é operação tributada); benefícios Loja e Viagens (1 ponto por real) e rendimento do saldo (parâmetros CDI 14,9% a.a., 100% do CDI). Compras altas pedem facial.

PJ: split automático no recebimento de cobrança com nota; cobrança (Pix/boleto), Pix Automático, pagamento em lote e webhooks; painel de imposto retido, repasse e créditos.

SLIDE 6

“Só no pagamento de uma cobrança com nota fiscal.”

> **Na tela**
> Regra do split deixada explícita: quando retém e quando não retém.

A lógica por trás (backend)

Retém quando o recebedor está no regime **regular e** a nota traz imposto > 0. **Simples/MEI**, cobrança **sem nota** e **transferência comum** → sem retenção.

Validação da nota antes de aceitar: **chave de 44 dígitos** com dígito verificador válido e o **CNPJ do emitente** (posições 7–20 da chave) **igual** ao CNPJ de quem está cobrando (`cobranca_service._validar_nota`).

SLIDE 7

“Simule qualquer venda.” — regimes e a referência de ≈ 26,5%

> **Na tela**
> Simulador: valor da venda, ano e regime → imposto estimado e líquido.

A lógica por trás (backend)

O simulador usa `split_service.estimar` com a tabela do ano e o fator do regime: padrão 100%, reduzido 70% (-30%), reduzido 40% (-60%) e zero. É **estimativa** (ordem de grandeza) — na prática a redução vale por produto/serviço (NCM/NBS), por isso o split **real** lê o imposto da nota, nunca estima.

SLIDE 8

“O login é da pessoa. O poder, da alçada.”

> **Na tela**
> Selos ‘Sempre da pessoa’, ‘CNPJ conferido’ e ‘Papel e alçada em reais’; governança da conta PJ.

A lógica por trás (backend)

Cada usuário da empresa é uma pessoa com credencial própria (login + biometria), um **papel** e uma **alçada** (teto em R$).

Papel	Pode fazer
Administrador(a)	Tudo, inclusive gerir usuários e aprovar operações.
Aprovador(a)	Aprovar operações acima da alçada de quem lançou; operar na própria alçada.
Operador(a)	Lançar pagamentos e cobranças dentro da própria alçada.
Só consulta	Ver saldo, extrato e relatórios, sem movimentar.

CNPJ conferido por dígito verificador e situação cadastral — provedor `stub` (dev) ou `brasilapi` (consulta pública da Receita).
Maker-checker: operação acima da alçada de quem lançou fica pendente e exige um segundo aprovador (≠ do criador, dentro da alçada dele).

SLIDE 9

“Da boas-vindas ao comprovante.” — o app REAL embutido

> **Na tela**
> Um celular com o app de verdade rodando dentro, ao lado do menu das 11 etapas. Clicar numa etapa leva o app àquela tela; a verificação facial abre a câmera. É aqui que se mostra cada fluxo e se explica a lógica correspondente.

As 11 etapas e a ação no backend

#	Etapa / tela	O que acontece no backend
01	Boas-vindas	Rota pública; nenhuma chamada sensível.
02	Login	POST login → JWT access (15 min) + refresh (7 d, rotacionado).
03	Verificação facial	Desafio do servidor + prova de vida + MFA (ver ficha adiante).
04	Início PF	Saldo da carteira; rendimento do saldo (CDI).
05	Pix / Transferir	transferir(): sem split; checa alçada, facial >R$500, risco, limites.
06	Início PJ	Troca de conta por X-Conta; cards de imposto retido e créditos.
07	Entenda o split	estimar() / tabela de transição 2026–2033.
08	Cobrar com nota	criar(): valida NF-e (chave + CNPJ); gera txid e parcelas.
09	Equipe & alçadas	Vínculos: papéis e alçada em R$.
10	Aprovações pendentes	decidir_pendente(): maker-checker, aprovador ≠ criador.
11	Comprovante	Transação com bruto, CBS, IBS, líquido e quem autorizou.

FICHA TÉCNICA

Verificação facial — a parte que mais perguntam

Qual API/biblioteca usamos

Motor: **DeepFace** (open-source). Reconhecimento com o modelo **Facenet** (embedding de **128 dimensões**), detector `opencv`, métrica de distância **cosine** e limiar dado pela própria DeepFace (`find_threshold`). Anti-spoofing com **MiniFASNet** (flag `anti_spoofing=True` → campo `is_real`), que barra foto/tela. Importação preguiçosa: a API e os testes sobem sem TensorFlow.

> **Por que não é “só chamar a lib”**
> A DeepFace entrega os **modelos prontos**. O que montamos do zero é a **prova de vida decidida pelo servidor**: antes rodava só no navegador (MediaPipe) e quem chamasse a API direto pulava a checagem. Agora quem decide é o backend.

Como funciona, passo a passo

- **1. Desafio.** O app pede `POST /biometria/desafios`; o servidor **sorteia** um movimento (virar à esquerda ou à direita), **uso único**, validade **120 s**, amarrado ao usuário logado (um desafio anônimo não serve para MFA).
- **2. Captura.** O app filma e envia **2 a 5 quadros**: o primeiro de frente, os seguintes durante o movimento pedido.
- **3. Anti-spoofing** em todos os quadros (MiniFASNet): se parecer foto/tela → reprovado.
- **4. Giro da cabeça.** Mede o deslocamento do ponto médio entre os olhos em relação ao centro da caixa do rosto (fração da largura): frontal precisa ficar abaixo de 0,08 e o giro precisa passar de 0,06, no sentido sorteado. Prova que a pessoa está viva e seguiu a instrução.
- **5. Comparação.** Extrai o embedding e compara com o cadastrado; se a distância passar do limiar → 401 genérico (o número fica só no log).

Privacidade, abuso e carga

- **LGPD:** guarda-se apenas a **assinatura matemática** do rosto (vetor), **nunca a foto**, e cifrada em repouso com **Fernet** (cryptography, chave `EMBEDDING_KEY`).
- **Rate limit:** 5 tentativas por 15 min por usuário → 429.
- **Carga:** a análise roda sob semáforo (2 simultâneas); sem vaga em 10 s → 503 (não derruba a API).
- **Modo de teste** (`BIOMETRIA_STUB=1`): aprova sem conferir o rosto — usado na demonstração para não depender de GPU/câmera.

FICHA TÉCNICA

Split da nota — como o dinheiro se separa

- Entrada: valor bruto + CBS + IBS **destacados na nota**. O banco **não recalcula** (`split_da_nota`).
- **Arredondamento exato:** cada tributo arredonda ao centavo (ROUND_HALF_UP) e o líquido é o **resto** → **cbs + ibs + líquido = bruto sempre** (coberto por teste).
- **Parcelamento:** N cobranças com valor/CBS/IBS proporcionais; a última parcela absorve os centavos, então a soma fecha com a nota.
- **Contas de sistema:** retido → `TRIBUTOS`; repasse D+1 → `FISCO`; depósitos saem de `CAIXA`.
- **Simulado de propósito:** o “copia e cola” do Pix e a linha digitável do boleto — emitir de verdade exige SPI/DICT (Pix) e convênio na Núclea (boleto).

SLIDE 10 · FICHA TÉCNICA

“Somos de cibersegurança.” — segurança no servidor

Ordem das checagens de uma transferência (as baratas primeiro): destino ≠ origem e papel/aparelho → alçada (acima vira pendente) → **MFA facial** acima de R$ 500 → **risco** (bloqueio cautelar) → saldo e limites **dentro do lock da carteira**, junto com o débito. **Idempotência** é por carteira de origem (duas pessoas com a mesma chave não se misturam).

Limites (Res. BCB 142/2021 e IN BCB 491/2024)

Limite padrão	Por transação	Diurno	Noturno (20h–6h)
Pessoa física	R$ 5.000	R$ 10.000	R$ 1.000
Pessoa jurídica	R$ 50.000	R$ 200.000	R$ 20.000

- **Reduzir limite** vale na hora; **aumentar** só após 24 h de carência (o cliente não sobe o limite no meio de um golpe).
- **Aparelho novo (PF):** até confiar no aparelho com uma facial, no máximo **R$ 200/transação** e **R$ 1.000/dia** naquele aparelho.
- **Bloqueio cautelar:** transferência ≥ R$ 1.000 para um destino **nunca usado** fica retida no recebedor por até **72 h** — janela para a contestação.
- **Contestação (MED):** admin contesta em até **80 dias**; se procedente, devolve; o imposto já retido segue a regra da transação.
- **Sessão e integridade:** JWT com rotação/detecção de reuso, idempotência, rate limit e **webhooks assinados** (eventos: `pix.recebido`, `cobranca.paga`, `operacao.pendente`…).

SLIDES 11–13

Onde estamos, sem exagero · Encerramento

É real (roda de verdade)	É simulado / fora do escopo
API completa com as regras acima; banco relacional; dupla aprovação; limites; split exato; prova de vida no servidor; testes automatizados (pytest) e TypeScript estrito.	Pix/boleto reais (precisam de SPI/DICT/Núclea); abatimento de crédito em tempo real (‘superinteligente’, depende da plataforma da Receita/CGIBS); na demonstração, a facial roda em modo stub.

Frase de fechamento

O app não é só telas: cada ação — criar conta, pagar, cobrar, aprovar — corresponde a uma rota da API com as mesmas regras de negócio e segurança. Há uma estrutura sólida por trás da interface.